

? RAPPORT D'AUDIT — Presentia (MeVoici)

Date : 2026-09-13 · **Projet** : C:\Dev\Presentia\Presentia

Type : Audit sécurité + recherche d'anomalies (incohérences, liens morts / routes inaccessibles)

Mode : 100 % lecture seule — aucune modification de code ni de base effectuée.

Méthode : 3 audits parallèles (agent sécurité OWASP / agent liens-routes / agent données) + vérification factuelle manuelle de chaque découverte (lecture des fichiers / requêtes SQL en base presentia).

?? VERDICT GLOBAL

? NON exploitable en production en l'état.

L'isolation multi-tenant (pierre angulaire d'un SaaS hébergeant PII de membres et données financières) est percée en plusieurs points critiques : autorisation ignore church_id, comptes privilégiés au mot de passe public, données non rattachées à une église. À régler prioritairement avant tout déploiement.

Axe	Résultat	Sévérité globale
Sécurité applicative	20 findings (5 critiques, 8 hauts, 4 moyens, 3 faibles)	?
Liens morts / routes	3 défauts confirmés (2 latents + 1 lien mort visible)	?
Données	Structure saine, mais detenacy massive + incohérence comptable	?

1?? AXE SÉCURITÉ

1.1 Secrets & configuration

? CRITIQUE — F-3 · Mots de passe par défaut en clair dans les seeders

- database/seeders/AdminSeeder.php:88 -> Super Admin SaaS admin@eber.org / Admin@1234!, statut ACTIVE.
- database/seeders/MemberSeeder.php:23, 35, 47, 66 -> Password@1234!, ACTIVE.
- database/seeders/ExecutiveSeeder.php:22, 34, 46 -> Password@1234!.
- database/seeders/ChartDataSeeder.php:82 -> Password@1234!.
- database/seeders/MinontinChurchSeeder.php:85, 101, 146, 163, 228 -> Admin@1234! / Tresor@1234! / Pass@1234!, ACTIVE.
- DatabaseSeeder.php appelle encore AdminSeeder (activé). Les statuts ACTIVE contournent ForcePasswordChange (qui ne bloque que PENDING).

- **Impact** : un `db:seed` exécuté en production (très courant) donne au monde entier le mot de passe du super-administrateur de la plateforme -> compromission de toutes les églises.

? HAUT — F-1 · Secrets réels en clair dans `.env`

- `.env:8 APP_KEY=base64:...` — clé de signature (QR signés inclus)
- `.env:7 APP_DEBUG=true`
- `.env:25-26 MAIL_USERNAME=teteganexauce@gmail.com` + mot de passe d'application Gmail réel
- `.env:32-33 ULTRMSG_INSTANCE_ID=instance184067` + token API WhatsApp réel
- ? Note : `.env` est bien gitignoré (`.gitignore:8`) ; `git ls-files` ne montre aucun `.env` committé. Risque si le fichier est déployé tel quel, sauvegardé/uploadé, ou si le dépôt est rendu public ailleurs.
- **Impact** : contrôle du SMTP Gmail (mails frauduleux), du compte UltraMsg (WhatsApp payants), falsification de la clé de signature des QR ; `APP_DEBUG=true` exposé = traces de pile, variables d'env, requêtes SQL.

? MOYEN — F-2 · `public/test_env.php` tracké dans git

- Contenu : infos de configuration PHP (`post_max_size...`). Accessible publiquement via le webroot. Fuite d'information mineure. Scripts racine similaires existent (`check_*.php`, `fix_*.php`, `update_*.php`, `create_role.php`, `test_excel.php`) -> à déplacer hors webroot.

1.2 Authn / Authz / IDOR (cœur du problème multitenant)

Constat structurel : l'isolation repose sur le scope global `ChurchScope` (`app/Models/Scopes/ChurchScope.php`, trait `BelongsToChurch`), mais ni `User`, ni `Role`, ni `AppSetting` ne l'utilisent. Le modèle `User` ne fait que binder `church_id` à la création. Les lectures ne sont jamais filtrées.

? CRITIQUE — F-4 · IDOR cross-tenant `admin/users/{user}`

- `app/Traits/HasHashid.php:53-56` : `resolveRouteBinding` accepte les IDs numériques bruts.
- `app/Helpers/HashHelper.php:18-22` : `decode_id` renvoie l'entier tel quel si numérique.
- `app/Policies/UserPolicy.php:36, 58, 83, 97` : `view/update/delete/restore` ne vérifient jamais `$model->church_id === $user->church_id` ; le `before` (l.14) donne tout à tout Administrateur.
- **Impact** : un admin de l'église A lit/modifie/supprime les membres (PII : email, téléphone, adresse, photos) de l'église B via `GET/PUT/DELETE /admin/users/{id-B}`.

? CRITIQUE — F-5 · Changement de statut de masse cross-tenant

- `app/Http/Controllers/Admin/UserController.php:244` :
`User::whereIn('id', $request->user_ids)->update(['status' => ...])` — aucun filtre `church_id`. Validation `exists:users,id` (l.240) accepte un ID de l'église B.
- **Impact** : un admin de l'église A suspend/active des comptes de l'église B -> déni de service ciblé.

? CRITIQUE — F-6 · Escalade de privilèges cross-tenant

- `app/Http/Controllers/Admin/PermissionController.php:22,73` :
`$churchId = $user->church_id ?? session(...)?->church_id` — utilise le tenant de l'utilisateur ciblé.
- `app/Services/PermissionService.php:66-94` : `syncUserRoles` synchronise les rôles dans l'équipe = église de la cible.
- **Impact** : un admin de l'église A assigne le rôle `Administrateur` de l'église B à un user B -> prise de contrôle totale de l'église B.

? CRITIQUE — F-7 · Émargement global cross-tenant

- `app/Http/Controllers/AttendanceManagementController.php:57` :
`$allEligibleQuery = User::whereNull('deleted_at')` -> liste de tous les utilisateurs de toutes les églises.
- `:126` : `$belongs = User::where('id', $userId)...exists()` — aucun contrôle de `church_id` -> création de `Registration/Attendance` cross-tenant.
- `:256` (`destroy`) et `:193` (`getUpdates` renvoie `full_name` + `email`) : idem.
- **Impact** : un `Président/Membre du bureau` marque présent un membre d'une autre église, altère des registres, exfiltre noms/emails.

? HAUT — F-8 · Affectation de membres cross-tenant dans les groupes

- `app/Http/Controllers/Admin/GroupController.php:75,114` : `leader_id/collector_id` validés `exists:users,id` sans contrainte d'église.
- `:148-170` : `assignMember` attache un `user_id` any-église au groupe (le groupe, lui, est scopé).
- **Impact** : exposition de l'identité d'un membre de l'église B, pollution des effectifs, notifications cross-tenant, possibilité d'assigner `Chef de groupe/Chargé de collecte` cross-tenant.

? MOYEN — F-9 · Notifications individuelles cross-tenant

- `app/Http/Controllers/Admin/NotificationController.php:66` :
`$users = User::orderBy('name')->get()` -> annuaire de toutes les églises.
- `:78-89` : `user_id` any -> envoi de notifications cross-tenant.
- **Impact** : fuite d'annuaire multitenant + contact de membres d'autres églises par tout admin avec `notification.send_individual`.

? FAIBLE — F-10 · `sendRole` avec `role_id` non scopé

- `app/Http/Controllers/Admin/NotificationController.php:52-64` : `Role::findOrFail(...)` -> fuite indirecte du nom d'un rôle d'une autre église.

1.3 Injection SQL

? Aucune injection SQL confirmée. Les seuls usages `DB::raw/selectRaw` sont à colonnes constantes (`StatisticsController.php:227,230,499,500`, `ContributionController.php:96`). Toutes les entrées passent par le query builder paramétré.

1.4 XSS

? HAUT — F-12 · XSS stocké via upload SVG (avatar, cover, galerie, logos)

- `app/Traits/OptimizesImages.php:33-35,61-62` : les fichiers `svg/ico` sont enregistrés bruts, contenu conservé.
- Règles `image` (ex. `ProfileController.php:44,63`, `GalleryController.php:18`, `GroupController.php:74,113`, `AppSettingController.php:51`, `ChurchController.php:211`) : acceptent `image/svg+xml`.
- Servis sous `/storage/...` (même origine) -> un SVG avec `<script>` s'exécute à l'ouverture.
- **Impact** : XSS dans l'origine de l'app (vol de cookie si non-HttpOnly, phishing, actions au nom de la victime). Accentué pour la **galerie** et les **logos d'église** affichés sur la page publique `/c/{slug}`.

? FAIBLE — F-13 · `{!! !!}` résiduel

- `resources/views/activities/attendance.blade.php:88` : `{!! $validationScopeMessage !!}` incorpore `$activity->group->name` (contrôlé par un admin). Échappement Blade globalement ? correct (champs RTE sortis en `{{ }}`).

1.5 CSRF / GET qui modifie l'état

? MOYEN — F-14 · Mutations d'état en GET sans token CSRF

- `routes/web.php:~186` GET `super-admin/churches/{church}/impersonate` -> modifie `session('tenant_church_id')` ; une `<img src=.../impersonate>` piégée force un Super Admin connecté à naviguer « en mode support » dans une autre église à son insu.
- `routes/web.php:~187` GET `leave-impersonation`.
- `routes/web.php:62` GET `notifications/{id}/read` -> `redirect($notification->data['url'])` (`app/Http/Controllers/NotificationController.php:35`) = open-redirect potentiel si notification malveillante.
- Les autres mutations (`toggle-status`, `renew`, `users/restore`, `galleries/toggle`) sont en

POST ? couverts par CSRF.

1.6 Session & requêtes

? F-15 Throttling login correct : 5 essais / 15 min par identifiant+IP (`app/Http/Requests/Auth/LoginRequest.php:48-95`), régénération de session (l.86), logout avec invalidation + régénération du token, anti-énumération de reset (`PasswordResetService.php:28-47`).

? MOYEN — F-16 · Durcissement incomplet

- `config/session.php:150` : `'secure' => env('SESSION_SECURE_COOKIE')` — non défini dans `.env` -> cookie session transmis en clair en HTTP.
- `bootstrap/app.php:20` : `$middleware->trustProxies(at: '*')` -> tous les proxies fiés : forge de `X-Forwarded-*` (falsification de `ip_address` des présences, contournement partiel du rate limiting, désactivation HTTPS).

1.7 Uploads

- Tailles jusqu'à 50 Mo (`max:51200`) sur avatar/cover/galerie -> DoS disque possible. Noms de fichiers aléatoires (`uniqid()+time()`), chemins constants -> pas de traversal. Revalidation du contenu absente (mime sniffé seulement). Lié à F-12.

1.8 Dépendances

? HAUT — F-18 · **composer audit** : 49 avis / 15 paquets (1 critique, 16 high, 24 medium, 7 low)

- `dompdf/dompdf` (<3.1.6) : CVE-2026-56722 (lecture fichier local via SVG data-URI), CVE-2026-59942/41 (DoS images) — dompdf sert à générer les PDF d'émargement/inscriptions/QR.
- `guzzlehttp/guzzle` : CVE-2026-69246 high (bypass de contrôles basés sur le host) — utilisé pour les API WhatsApp.
- `laravel/framework` : CVE-2026-48019 high (CRLF injection dans la règle `email`).
- `symfony/http-kernel` : CVE-2026-45075 high (le verbe HEAD contourne les filtres `methods:['GET']` des gates CSRF/signature) — pertinent pour `attendance/validate` (`get|post`).
- Autres touchés : league/commonmark, phpooffice/phpspreadsheet, symfony/http-foundation, maatwebsite/excel, guzzlehttp/psr7, symfony/mailer.

1.9 Signatures d'URL — QR présence

? HAUT — F-19 · Bypass d'expiration des URLs signées (**attendance.validate**)

- `app/Http/Controllers/AttendanceController.php:20-50` : quand `isValidSignature()` renvoie false, le fallback manuel recalcule `hash_hmac('sha256', $url, config('app.key'))` sans vérifier le timestamp **expires** -> une URL expirée avec sa signature d'origine matche toujours -> acceptée.
- `:31-32` : hôtes `http://localhost:8000` / `http://127.0.0.1:8000` toujours « valides ».
- **Impact** : un QR capté (photo, capture) après `end_time` reste utilisable **indéfiniment** -> fraude d'émargement.

1.10 Gestion d'erreurs / logging

- `config/app.php:42` lit `APP_DEBUG` -> si `true` en prod, traces complètes. Pas de vue d'erreur custom (dossier `errors` vide). Logging `single` niveau `debug` (pas de rotation `daily`).

2??? AXE LIENS MORTS / ROUTES INACCESSIBLES

124 routes nommées définies (122 web + 2 Fortify) · 329 appels `route()` dans les vues couvrant 114 noms — **tous** valides, hormis ci-dessous. Aucun `@include/@extends` cassé, aucun asset PWA manquant (manifest, sw.js, offline.html, icônes ?).

? HAUT (visible utilisateur) — Liens **#contact** pointent dans le vide

- `resources/views/welcome.blade.php:1371, 1470, 1614` : 3 boutons `href="#contact"` (« Contacter le secrétariat pastoral »...).
- Les sections de la page portent les ids `#about`, `#organization`, `#groups`, `#gallery`, `#events` — **aucun élément `id="contact"`** (le footer « Contact » n'a pas d'id).
- **Impact** : au clic, rien ne se passe (l'ancree n'existe pas, pas de scroll vers un formulaire de contact). La fonctionnalité « contacter le secrétariat » semble **absente** de la page principale.

? MOYEN (latent) — Nom de route inexistant **attendance.scanner**

- `app/Http/Controllers/AttendanceScanController.php:37` : `redirect()->route('attendance.scanner')` — la route définie s'appelle `scan.alias` / `attendance.scan` -> `RouteNotFoundException` si le code s'exécute.
- La méthode `scan()` elle-même n'est mappée par **aucune** route de `web.php` -> code mort latent ; la

redirection de repli d'un scan QR est cassée.

? MOYEN (latent) — `admin.activity-types.show` sans méthode contrôleur

- `routes/web.php:100` : `Route::resource('activity-types')` génère `{activity_type}.show`, mais `app/Http/Controllers/Admin/ActivityTypeController.php` n'a pas de méthode `show()` (index/create/store/edit/update/destroy seulement) -> `GET /admin/activity-types/{id} = HTTP 500`.
- Aucune vue n'y pointe (aucune référence), mais la route est enregistrée et accessible par URL directe.

? Vérifications positives

- Params d'URL : `route('church.landing', slug)` ?, hash IDs décodés via `App\Traits\HasHashid` (`admin/users.show`, QR) ?, `remittance` via `HasHashid` ?. Aucun appel `route()` sans paramètre obligatoire.
- Frontend/PWA : `resources/js/app.js` sans routes en dur ; les `fetch/axios` inline pointent vers des routes définies (`statistics.chart.`, `attendance.`, `global-search`) ? ; `manifest.json` shortcuts (`/dashboard`, `/admin/activities`, `/admin/groups`) -> existantes ?.
- Double enregistrement `/login`, `/forgot-password`, `/logout` entre `web.php` et Fortify (`web.php` prime — inoffensif mais risqué). POST `admin.notifications.send-*` anonyme (match par URI+méthode, fonctionne).

3?? AXE ANOMALIES DE DONNÉES (base `presentia`)

Audit 100 % `SELECT` (aucune écriture). Structure : 0 référence cassée, 0 doublon email/téléphone, 0 orphelin, 0 user supprimé.

3.1 Volume de la tenancy

Entité	Total	<code>church_id = NULL</code>	<code>church_id = 1</code>
users	82	80 (97,6 %)	2
roles	9	1 (Super Admin, global)	8
model_has_roles	92	0	92
groups	9	8	1 (« Dxne », test)

group_members	76	75	1
contributions	2 106	2 106 (100 %)	0
remittances	0	—	—
activities	20	20 (100 %)	0
activity_types	6	6 (100 %)	0
attendances	460	460 (100 %)	0
registrations	0	—	—
subscriptions	1	—	1
galleries	0	—	—
app_settings	1	1 (100 %)	0
audit_logs	2 776	2 767 (99,7 %)	9
whatsapp_logs	3	3 (100 %)	0
scheduled_notifications	0	—	—

? CRITIQUE — Users **church_id = NULL** (80/82)

- Ex. : id 2 **chef_bethel@eber.org**, id 3 **adjazo-dorcas@eber.org**, id 12 **chef_cana@eber.org**... Seuls id 1 **admin@eber.org** et id 82 (**alassanemomo244@gmail.com**) ont **church_id=1**.
- La migration **2026_09_01_000003_add_church_id_to_tenant_tables** a ajouté la colonne NULL **sans backfill** des lignes existantes ; le **creating** hook du **User** ne couvre pas les anciens comptes.
- Impact** : quand **\$user->church_id** est NULL, **ChurchScope** **n'applique aucun filtre** -> ces 80 users voient les données de toutes les églises (fuite) ; à l'inverse, leurs groupes/cotisations/présences (aussi NULL) sont invisibles au scope de l'église 1.

? HAUT — Toutes les données métier détachées du tenant

- 8/9 groupes (Béthel...Sinaï), 20/20 activités, 6/6 types, 2 106/2 106 cotisations (~ 2 639 000 FCFA), 460/460 présences, 1/1 app_settings, 2 767 audit_logs, 3 whatsapp_logs -> **church_id = NULL**.
- Impact** : un admin scopé église 1 ne voit ni ses groupes, ni ses activités, ni ses cotisations tant que le backfill n'est pas fait ; le pépinière comptable est non-typée.

? CRITIQUE (comptable) — ~ 2 639 000 FCFA de cotisations SANS aucun versement

- Table **remittances** **vide (0 ligne)** alors que 2 106 cotisations existent (fév. -> juil. 2026, 324->405/mois). Aucune cotisation n'a de **remittance_id**.
- Impact** : soit le process « versement trésorerie » n'a jamais été utilisé, soit le journal a été perdu lors de la refonte multitenant. **Aucune contrepartie comptable** pour ~2,6 M FCFA.

? MOYEN — Incohérence tenant rôle vs user

- Les 92 assignations `model_has_roles` sont `church_id=1` (rôles scopés église 1), mais 80 des users concernés ont `users.church_id = NULL` -> la résolution Spatie (teams) des permissions de ces 80 users est fragile.

? MOYEN — 6 comptes ACTIVE sans groupe

- id 1 `admin@eber.org` + id 77-81 `visiteur-jean/marie/paul/sophie/lucas@eber.org` (tous rôle « Jeune »). Désactiver ou rattacher.

? Sain

- 0 doublon email/téléphone · 0 orphelin (groupes.leader_id/collector_id, group_members, activities.activity_type_id/responsible_id, attendances, audit_logs) · église Eber : statut `active`, abonnement valide (150 000 FCFA/an, exp. 2027-09-12) · remittances/galleries/registrations vides sans anomalie.

4?? PLAN DE REMÉDIATION PRIORISÉ

P0 — avant toute mise en production

1. **F-4/F-5/F-6/F-7/F-8/F-9** — Appliquer le scope tenant à `User` (+ `Role/AppSetting`) et ajouter les contrôles `church_id` dans `UserPolicy` / `GroupPolicy` (avant le `before` Admin), dans `PermissionController` (`abort_if` si `$user->church_id !== auth()->user()->church_id` et non SuperAdmin) et dans `AttendanceManagementController` (filtrer par `$activity->church_id`).
2. **Data — Backfill tenancy** : `UPDATE church_id = 1` sur users (80), groups (8), activities (20), activity_types (6), contributions (2 106), attendances (460), app_settings (1), audit_logs (2 767), whatsapp_logs (3) — après validation du sort des 6 comptes sans groupe et du groupe test « Dxne ». (Note : `AdminSeeder` étape 3 backfill déjà les NULL si `db:seed` est relancé — préférer une migration dédiée.)
3. **F-3** — Comptes seedés en `PENDING` (+ `ForcePasswordChange`), mots de passe temporaires par canal chiffré ; ne pas exécuter `db:seed` en prod.
4. **F-1** — Rotation de `MAIL_PASSWORD`, `ULTRMSG_TOKEN`, régénération de `APP_KEY` ; `APP_DEBUG=false`, `APP_ENV=production` en prod.

P1 — avant release

5. **F-19** — Vérifier `expires` dans le fallback de `AttendanceController` (ou `URL::hasValidSignature($request, true)`) ; retirer la confiance `localhost`.
6. **F-12** — Bloquer `image/svg+xml` sur les uploads publics (ou sanitizer + `Content-Disposition` /

`X-Content-Type-Options: nosniff`).

7. **F-18** — `composer update` : dompdf >=3.1.6, guzzle >=7.15.2/8.0.1, laravel/framework corrigé, symfony/http-kernel corrigé -> relancer `composer audit`.
8. **F-14** — Passer `impersonate`, `leave-impersonation`, `notifications/{id}/read` en POST (ou idempotent non sensible) ; supprimer la redirection basée sur `notification->data['url']`.
9. **Liens** — Corriger les liens `#contact` (créer la section/id `contact` ou pointer vers une page de contact réelle) ; corriger `attendance.scanner` -> `attendance.scan` (ou retirer le code mort) ; ajouter `show()` à `ActivityTypeController` ou restreindre la resource.

P2 — durcissement

10. **F-16** — `SESSION_SECURE_COOKIE=true` en prod ; `trustProxies` avec liste explicite ; forcer HTTPS.
 11. **F-2** — Supprimer `public/test_env.php` et les scripts racine debug.
 12. **F-13** — Échapper/construire `$validationScopeMessage` sans données non fiables.
 13. Limiter les uploads à 2–5 Mo ; throttle sur les routes admin sensibles (`users/bulk-status`, `groups/members`).
-

? Points sains confirmés

- Aucune injection SQL · échappement Blade correct · CSRF sur mutations POST · throttling login (5/15 min) · régénération de session · `.env` gitignoré · PWA complète (offline.html, icônes, sw.js) · 124 routes web cohérentes (114 noms référencés valides) · base sans orphelin significatif · abonnement Eber conforme.
-

Rapport généré par audit automatisé multi-agents — découvertes vérifiées factuellement (lecture de fichiers + requêtes SELECT). Aucune modification effectuée.